DevSecOps—安全融入开发、运营的良好时机

张嵩

从一个RSA Seminar说起

Observations and benefits of DevSecOps

- Consistent application of security controls across all builds, applications & releases
- Decrease in Defect Density from 1.0 to 0.1
- Increase in the security integrity of applications
- Increase in remediation efficiency through continuous feedback
- Release gating/security gating
- Rapid deployment/increased speed to market
- Increase in efficiency & scalability (Microservices)

Challenges Moving to DevOps

- Evolving the culture and habits of 3500+ developers
- Multiple "flavors" of DevOps in different parts of the organization
- Security tool integration in a manner that supports objectives for actionable continuous feedback
- What is the best approach for integrating threat modeling and manual assessments into the lifecycle without impacting CD objectives?

aetna

Aetna's Journey

--a health care and insurance company regulated by HIPAA

The seeds of DevOps are germinating everywhere

- 3500+ Developers
- 1500+ Applications
- Multiple deployment platforms and development languages
- Robust Software security program and training programs
- Formerly a "Waterfall" organization, but evolving people and resources to support DevOps
- Mature DevOps practices in some facets of the organization and subsidiaries
- Evolving legacy apps to support Microservices design principles and containerization
- The evolution of SDLC from Waterfall to DevOps
- Integration of Software Security Program into the CI/CD Process:
  - Fully Automated Static Code Analysis
  - Container Vulnerability Scanning
    - CIS Docker Benchmarks as a guideline
    - Commercial software
  - Identifying and remediating AWS Security Risk
  - Automate threshold reduction as vulnerabilities in code decreased
- We measure ourselves (KPI)—Defect Density
- Constantly learning, improving, and re-evaluating

"DevOps and Security—an Unprecedented Opportunity"

- Automation/Tool Integration
- Transparency
- Increased Collaboration
- Consistent Adoption
- Continual Feedback
- Remediation Efficiency
- Release Gating
- Resiliency & Scalability（Microservices/Containers）

DevSecOps ?

什么是DevSecOps? Why?

- Gartner 2012年在一份报告中提出的概念。在这份报告中，Gartner提出**信息安全专业人士需要更主动地融入DevOps的实践中，秉承DevOps的精神，拥抱“团队协作、敏捷和职责共担的哲学”。**

- 基于Gartner的调研，估计少于20%的企业安全架构师参与到DevOps的项目中，主动和系统性地将信息安全融入DevOps项目，更少的组织达到了DevSecOps所需的安全自动化程度。

- Gartner认为**通过采用一些良好实践，安全架构师可以设计一系列可集成的控制措施，优化安全活动，同时，并不损害DevOps的敏捷和协作精神。**

企业的内在需求和管理层指导：

- “在质量可以接受的前提下，快速交付，尽可能提升研发和部署效率，守住安全底线”

- 恰恰，DevSecOps的理念和实践，可以帮助企业、IT组织的各个干系人朝着共同的目标努力

DevSecOps意味着应用安全怎样的改变?

(from: Practical AppSec Lessons learned in the Age of Agile and DevOps, RSA’17)

从：“代码部署前，要尽各种可能消灭掉可能存在的bug/缺陷、漏洞”的理念/mindset

到：聚焦在从部署的应用中，持续地获取反馈，增进了解、可视(visibility)和感知，提供安全的能力，这些能力可以让开发人员、运维人员、DevOps人员自主交付安全(security self-sufficient)

安全，从 “守门人”(Gatekeeper)演变到，赋能(enable)各团队,缺省就处于安全的状态

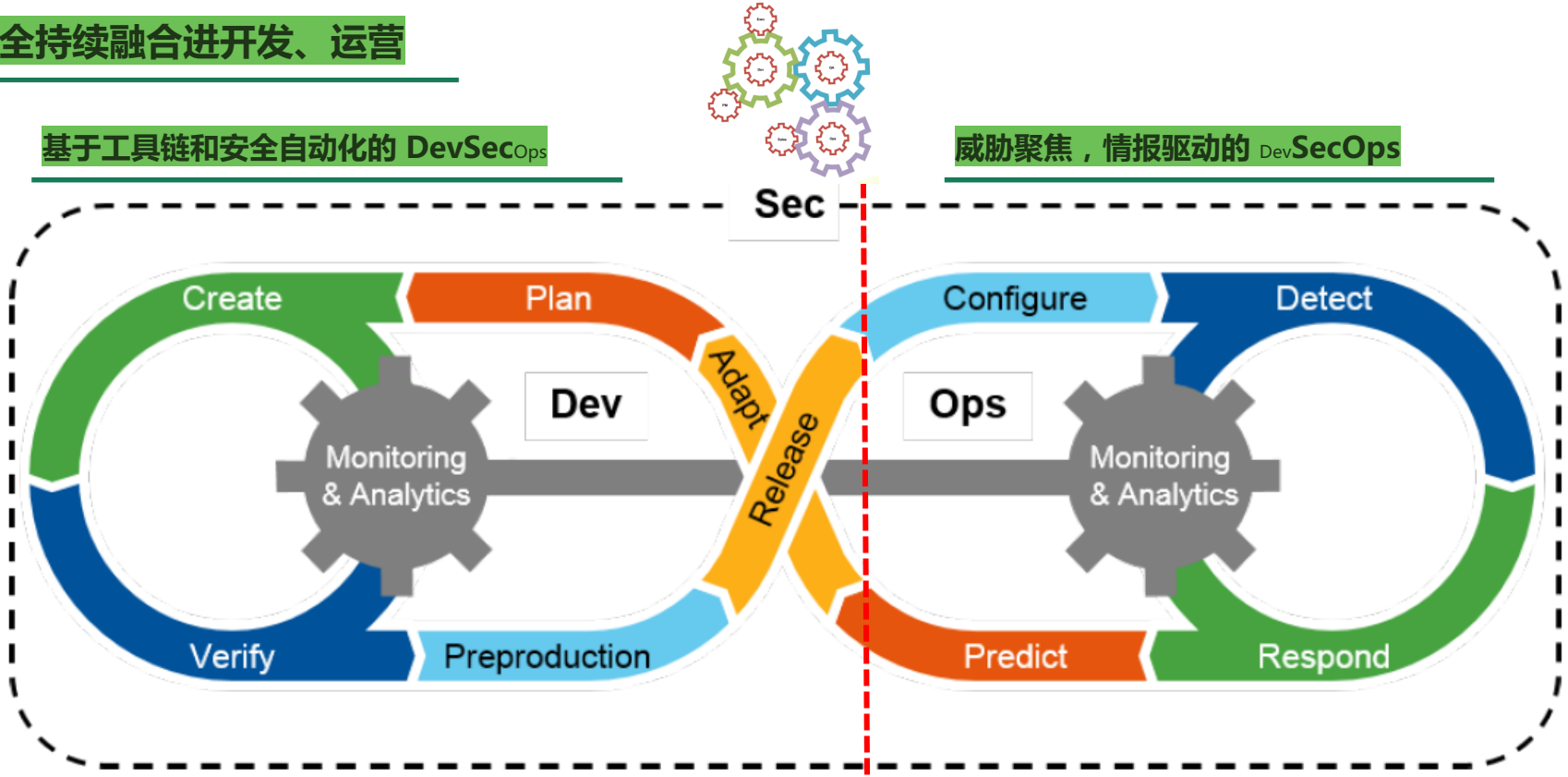
Security shifts from being a gatekeeper to enabling teams to be secure by default.

可进一步参考: *gartner.com, devops.com, devsecops.com, ruggedsoftware.org*

安全持续融合进开发、运营

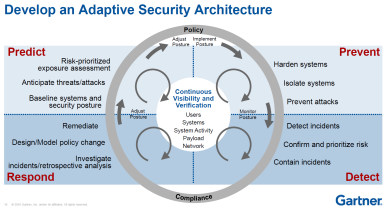
基于工具链和安全自动化的 DevSecOps

威胁聚焦，情报驱动的 DevSecOps

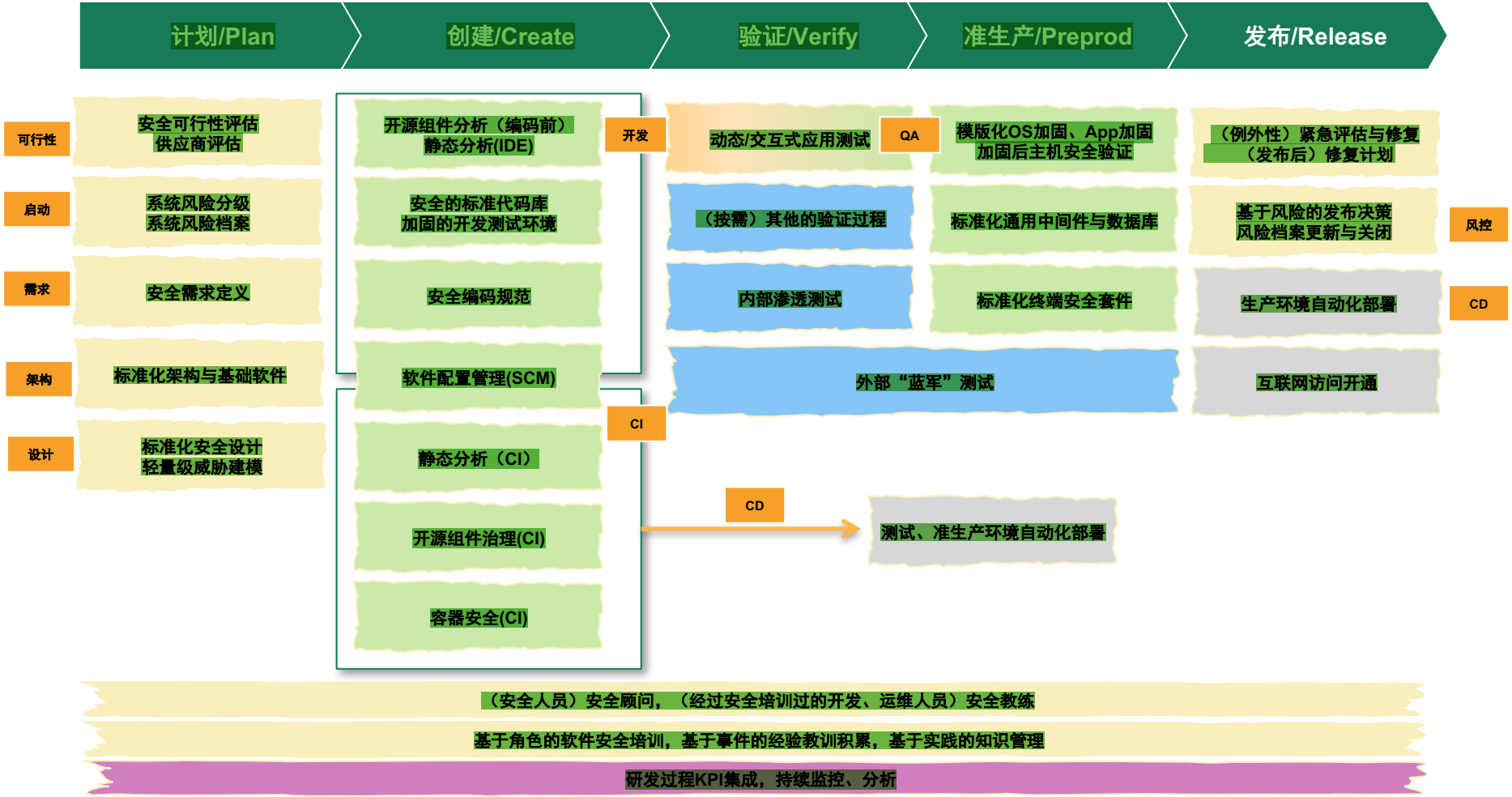


图片引用自:Gartner,DevSecOps: How to Seamlessly Integrate Security Into DevOps

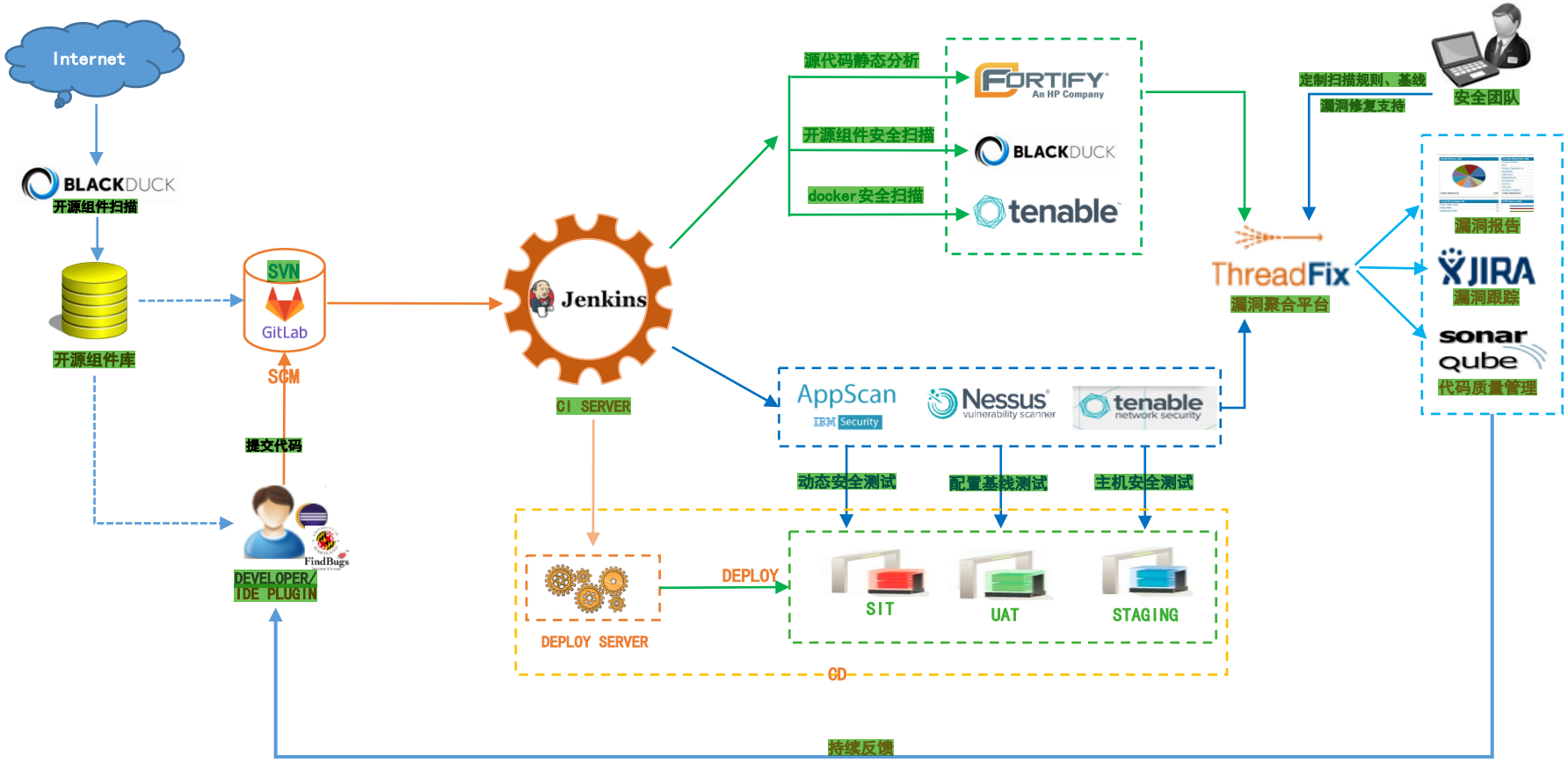
Gartner 适应性安全架构 (ASA)



基于工具链和安全自动化的：DevSecOps



DevSecOps工具链集成



Takeaway

- DevOps趋势已经在国内开启了，安全面临一个难得的融入机会
- 安全测试工具不应再是过去的由外包人员定期“撸”一下，应持续运营；从资产、漏洞等基础安全数据开始运营
- 威胁情报的应用，别再犹豫了，用起来，提升安全分析效率
- 开始了解威胁生命周期的管理，引入安全分析、威胁猎捕(Threat Hunting)成熟度模型，降低MTTD/MTTR为目标